

SaaS要点資料（法務向け・利用規約／プライバシーポリシー作成用 第一版ドラフト）

目的: 弁護士・行政書士が **利用規約（ToS）** および **プライバシーポリシー** を起案するために、本SaaSのシステム概要・取得する個人データ・データの流れ・外部委託先・保存場所をまとめた資料。作成: CC（第一版ドラフト・2026-06-22）。**機微な業務判断**（**保持期間・第三者提供方針・損害賠償の立て付け等**）は事業者がレビュー・確定すること。文中 **【要確認】** は事業者の確認が必要な箇所。

0. 事業者・サービスの基本情報

項目	内容
事業者名	Stism LLC 【要確認: 正式名称（合同会社/株式会社）・所在地・代表者】
サービス名	sido（内装施工会社向け 施工台帳自動化システム） 【要確認: 対外的なサービス名称】
サービス概要	内装施工会社向けに、日報・経費・勤怠・現場/下請け/車両などの施工台帳業務をLINE（LIFF）と管理画面で自動化するSaaS
提供形態	マルチテナント型クラウドサービス（施工会社ごとにテナント分離）
課金	【要確認: 料金体系・課金主体・解約条件】

1. 利用者・データ主体の種別

種別	説明	主な利用面
テナント（契約会社）	本サービスを契約する施工会社	管理画面
管理者ユーザー	テナント内の管理担当者	管理画面（admin・メール/パスワード認証）
作業員	テナントに属する従業員・職人	LINE LIFF フォーム（日報・経費・勤怠）／一部はメール/パスワードでもログイン
下請け業者の担当者	注文書承諾・請求入力を行う外部業者	トークン付きURL（限定公開ページ）

データ主体には **従業員（作業員）** と **取引先（下請け業者）担当者** が含まれる。従業員の個人データ（勤怠・位置情報・経費）を事業者が取り扱う点が、**労務・個人情報の両面で論点**になる。

2. 取得・保存する個人データ一覧

保存先はすべて Supabase（PostgreSQL／Storage）。テーブル単位の概要。**太字＝機微度が高い項目**。

2-1. 本人特定・認証

データ	保存場所（テーブル）	備考
氏名（作業員・管理者）	workers, users	
LINEユーザーID	users.line_user_id	LINEログイン連携時に取得
メールアドレス	users, 管理者認証（Supabase Auth）	

パスワード	Supabase Auth（ハッシュ化・自前保存なし）	bcrypt等でハッシュ管理
電話番号・住所	subcontractors, contractors ほか	主に取引先。【要確認: 作業員の住所/電話を取得するか】
生年月日	スキーマ上に birth 系列あり	【要確認: 実運用で取得しているか・用途】

2-2. 勤務・行動データ（従業員）

データ	保存場所	備考
日報（作業内容・勤務時間・休憩）	daily_reports (sites JSON)	日次の労働実態
出退勤の打刻・位置情報（GPS 緯度/経度）	attendance_logs (lat/lng・checked_at)	位置情報＝要配慮度高。取得目的の明示と同意が要点
同意記録（送り出し資料・現場ルール）	attendance_logs.agreed_document_names / agreed_rule_texts	誰が・いつ・何に同意したかの証跡
勤怠・予定（スケジュール）	schedules, schedule_groups ほか	
労務費・賃金関連	労務費集計（daily_reports由来）	【要確認: 賃金/単価データの取扱い範囲】

2-3. 経費・金銭データ

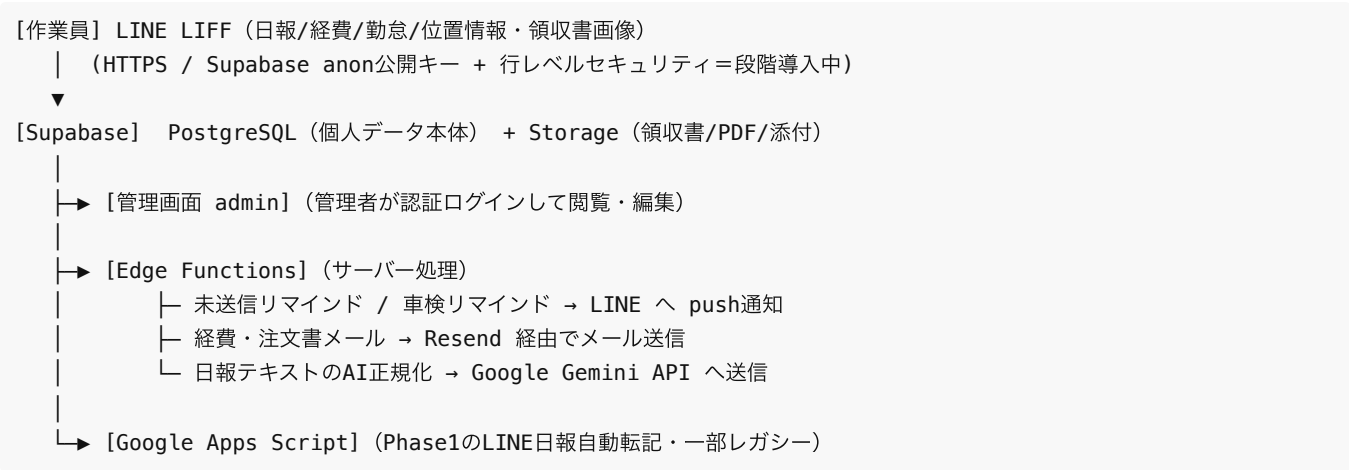
データ	保存場所	備考
経費明細（駐車・高速・電車・立替等）	daily_reports (sites JSON) , expense_items(レガシー)	
領収書画像	Supabase Storage（expense-receipts バケット・署名URL配信）	画像にナンバープレート・氏名等が写り込む可能性
経費申請PDF（明細・請求書）	Supabase Storage	
下請け業者の銀行口座情報	subcontractors（bank/口座/account_number 系列）	支払用の口座番号＝機微。取引先の金融情報
注文書・見積・請求	purchase_orders, estimates, subcontractor_invoices	取引先の取引情報

2-4. マスタ・その他

データ	保存場所
現場情報・現場添付資料	sites, site_attachments（非公開バケット・署名URL）
車両情報（ナンバー・車検日・保険）	vehicles, vehicle_repair_logs
下請け業者マスタ・連絡先	subcontractors, subcontractor_contacts

【要確認】マイナンバー・社会保険・口座以外の金融情報は **取得していない** 認識（スキーマ上に該当なし）。事業者側で別途取得している情報があれば追記が必要。

3. データの流れ（収集→保存→利用→提供）



- **位置情報:** 出退勤チェックイン時に取得し attendance_logs に保存。
- **領収書画像/PDF:** Supabase Storage に保存し、閲覧は短時間有効の署名URLで配信（公開URLではない）。
- **AI正規化:** 日報テキスト等を Google Gemini に送信して整形。【要確認: Gemini に送る内容に個人名等が含まれる前提で、AI委託先への提供を規約・PPに明記】
- **LINE通知:** リマインド等を作業員/管理者のLINEへ push。

4. 外部委託先（サブプロセッサ）と保存場所・国

委託先	役割	データ所在地
Supabase（DB/認証/ストレージ/Edge Functions）	個人データ本体・画像の保存と処理	リージョン ap-northeast-2（ソウル・韓国） 【要確認: 本番プロジェクトのリージョン。韓国保管＝越境移転の論点】
Vercel（ホスティング）	LIFF/管理画面の配信（フロントエンド）	エッジ配信。【要確認: リージョン】
LINE（LINEヤフー）	LIFFログイン基盤・push通知	日本 ほか
Resend	メール送信（経費申請・注文書承諾）	米国 【要確認】
Google（Gemini API）	日報テキストのAI正規化	【要確認: リージョン・データ学習利用の有無（APIのデータ利用ポリシー）】
Google（Apps Script）	Phase1レガシー処理	米国 ほか

越境移転の主要論点: 個人データ本体が **韓国（Supabaseソウルリージョン）** に保管される前提。外国にある第三者への提供／越境移転に関する同意・公表が必要になる可能性が高い。データ所在地は事業者がSupabase ダッシュボードで確定すること。

5. データ保持・削除【要確認・事業者が方針決定】

- 保持期間（日報・勤怠・経費・領収書画像・退職者データ等）：【要確認】
- テナント解約時のデータ取扱い（削除/返却/猶予期間）：【要確認】
- 作業員退職時の個人データ削除フロー：【要確認】

6. セキュリティ（現状の実装）

- 通信はHTTPS。管理画面はメール/パスワード認証（Supabase Auth）。
- 領収書・現場添付資料は **非公開バケット＋短時間署名URL** で配信（公開URLにしない）。

- 行レベルセキュリティ（RLS／テナント分離）は **段階導入中**。一部マスタ系テーブルは現状RLS未適用で、公開anonキー前提のデータ保護強化を別途進行中（社内タスクで対応中）。
- 下請け業者ページはトークン付きURL（期限・失効あり）でアクセス制御。

【要確認】規約・PPでは「適切な安全管理措置を講じる」旨を記載しつつ、過度に具体的な実装は約束しすぎない立て付けが望ましい（法務判断）。

7. 法務に確定してもらいたい論点（チェックリスト）

- 取得する個人データの **利用目的** の特定・公表（特に位置情報・労務・経費）。
- 位置情報（GPS）** の取得についての同意取得方法と目的明示。
- 外国（韓国/米国）の第三者への提供・越境移転**（Supabase/Resend/Google）の同意・公表。
- AI（Gemini）への個人データ提供**の位置づけ（委託 or 第三者提供／学習利用の有無）。
- 従業員（作業員）の個人データを **事業者（施工会社）が取り扱う** 構造の整理（テナント＝個人情報取扱事業者、当社＝委託先という整理でよいか）。
- データ **保持期間・削除** ポリシー。
- 取引先（下請け）の **口座情報等** の取扱い。
- 規約上の **責任制限・SLA・解約時データ取扱い・準拠法/管轄**。

付録: 主なデータテーブル（参考）

accounts（テナント） / users・workers（利用者） / daily_reports（日報・経費JSON） / attendance_logs（勤怠・位置情報・同意記録） / expense_*（経費） / subcontractors・subcontractor_*（下請け・口座・請求） / purchase_orders・estimates（注文書・見積） / sites・site_attachments（現場・添付） / vehicles（車両） / schedules（予定）。

本資料はシステム構成に基づく第一版。【要確認】 箇所を事業者が埋め、法務が規約・PPに落とし込む想定。